

# Information Security and Data Protection Policy

|                |                                                    |
|----------------|----------------------------------------------------|
| Document owner | Security Office                                    |
| Effective date | 2026-01-01                                         |
| Review cycle   | Annual or after material regulatory/process change |
| Audience       | All employees, contractors, and people managers    |

## Data Classification

Company information is classified as Public, Internal, Confidential, or Restricted. Customer data, employee records, credentials, source code, unreleased financials, and security findings are Confidential or Restricted unless formally reclassified.

Employees must apply the minimum access necessary to perform their role and store sensitive information only in approved systems.

| Classification | Examples                           | Handling rule                |
|----------------|------------------------------------|------------------------------|
| Public         | Published marketing pages          | Approved for external use    |
| Internal       | Team procedures, internal roadmaps | Company access only          |
| Confidential   | Customer contracts, employee data  | Need-to-know access          |
| Restricted     | Credentials, regulated data        | Highest controls and logging |

## Password and Authentication Rules

Employees must use unique passwords managed through the approved password manager. Multi-factor authentication is required for company systems, cloud applications, source repositories, and administrative tools.

Passwords, API keys, recovery codes, and session tokens must not be shared in chat, email, documents, screenshots, or code repositories.

## Security Incident Reporting

Suspected phishing, lost devices, malware alerts, accidental data sharing, credential exposure, or unauthorized access must be reported to security@example.com within one hour of discovery.

Employees should preserve evidence, avoid deleting suspicious emails or logs, and disconnect affected devices from networks if instructed by Security.

## Device and Network Security

Company laptops must run approved endpoint protection, disk encryption, automatic screen lock, and operating system updates. Jailbroken or rooted devices must not access company systems.

Public Wi-Fi should be used only with company-approved VPN where required. Sensitive work must not be performed on shared public computers.

## **Data Retention and Sharing**

Documents should be retained according to the retention schedule and legal hold requirements. Restricted data must not be exported to personal storage, consumer AI tools, or unapproved collaboration platforms.

External sharing requires a business purpose, appropriate recipient verification, and approved access controls such as expiration dates or watermarking when available.

## **Third-Party and AI Tool Use**

Vendors handling company or customer data must complete security review before access is granted. Employees must not paste Confidential or Restricted data into external AI tools unless the tool is approved for that data class.

Generated content used for customer, legal, financial, or security decisions must be reviewed by a qualified employee before use.